■ AVALOK SECUREMAILSCOPE

REPORT #c4ba2085
2026-09-29T19:33:47

Passive Email TLS Forensics • NIST SP 800-52 • RFC 8996 Compliance

CONFIDENTIAL EVIDENCE

1. FORENSIC EVIDENCE & CHAIN OF CUSTODY

■■ **INTEGRITY STATEMENT: No active network connections were made during analysis.** PASSIVE_OFFLINE (Air-Gapped / Strictly Read-Only)

Report ID:	`c4ba2085-7b6e-46e7-93d8-fb7e8866f4be`	**Analysis ID:**	`75e24868-1749-4764-9da0-9a1b7562978b`
Source PCAP:	capture.pcap (2,592 bytes)	**Generated At:**	2026-09-29T19:33:47.173634+00:00
PCAP SHA-256:	`0c96a199e6790537cec5f73b0d9b9730e0852bb8e22eadc8bd0320f8605e7ddc`	**Analyzer Version:**	SecureMailScope v1.0.0
Operational Mode:	100% Offline / Air-Gapped (Read-Only)	**Report SHA-256:**	`b241ca230c60ca2cf9b7a82d1a9808cd064ebb9019bb5827b6c5ae15d64b34c2`

2. EXECUTIVE SUMMARY & POSTURE ASSESSMENT

HOSTS ANALYZED	SESSIONS	TOTAL FINDINGS	CRITICAL	HIGH	MEDIUM	LOW
4	4	7	1	3	3	0

Host / Endpoint	Posture Grade	Risk Score	Findings Breakdown	Posture Delta
198.51.100.5:25	**Grade E** Poor	60 / 100	Crit: 0 | High: 2 | Med: 1 | Low: 0	No change from E (last scan 2026-09-29)
45.33.32.156:25	**Grade D** Weak	50 / 100	Crit: 1 | High: 0 | Med: 1 | Low: 0	No change from D (last scan 2026-09-29)
203.0.113.50:25	**Grade D** Weak	35 / 100	Crit: 0 | High: 1 | Med: 1 | Low: 0	No change from D (last scan 2026-09-29)
203.0.113.10:25	**Grade A+** Excellent	0 / 100	Crit: 0 | High: 0 | Med: 0 | Low: 0	

■ **PASSIVE TLS 1.3 VISIBILITY NOTE:** TLS 1.3 encrypts most handshake fields after ServerHello. Certificate details and some handshake parameters may not be visible in passive captures. Affected sessions are flagged with 'tls13_visibility_limited: true'.

3. SESSION FORENSICS & SECURITY FINDINGS

Host: 198.51.100.5:25 — Grade E (Poor) (Score: 60)

■■ **SECURITY POSTURE GRADE: E — POOR (Risk Score: 60/100, Bracket: 51-75)**
Host '198.51.100.5:25' received Posture Grade E (Poor) with a cumulative risk score of 60/100 (Bracket: 51-75). This grade was determined by 3 adverse findings (2 High, 1 Medium).

■ **Host Posture Score Breakdown:** 60 / 100 (Grade E) — 3 security findings mapped to score contributions.

```
Host Posture Score (198.51.100.5:25 - Grade E [Poor]): 60 / 100
Severity: GRADE E (POOR)

WHY?
■■■ TLS Protocol Version (TLS Version...   +40
■■■ Cipher Suite Security (Cipher Sui...   +25
■■■ Forward Secrecy (PFS) (Key Exchan...   +10
■■■ Total                                  60
```

Session #1: SMTP STARTTLS	**Flow:** 10.0.1.20:55001 → 198.51.100.5:25	**TLS Version:** TLS1.0	**PFS:** NO (No PFS)
Cipher: TLS_RSA_WITH_AES_128_CBC_SHA	**Key Exch:** RSA	**SNI:** None	**ML Risk:** medium (35%)

■ **WHY THIS SCORE? — Transparent Risk Reasoning** **Risk Score: 75 / 100 (HIGH)**

```
Session Risk Score: 75 / 100
Severity: HIGH

WHY?
■■■ TLS Protocol Version (TLS Version...   +40
■■■ Cipher Suite Security (Cipher Sui...   +25
■■■ Forward Secrecy (PFS) (Key Exchan...   +10
■■■ Total                                  75
```

Finding / Feature	Observed on Wire	Impact	Severity	Evidence Ref	Reason & Rationale
TLS Protocol Version deprecated-tls-10	`TLS Version: TLS1.0`	+40	[HIGH]	Packet #8 (Offset 0)	Deprecated TLS 1.0 protocol (RFC 8996 violation, vulnerable to BEAST/POODLE attacks)
Cipher Suite Security weak-cipher	`Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA`	+25	[HIGH]	Packet #8 (Offset 0)	Insecure CBC/RC4/3DES or non-AEAD cipher suite negotiated without modern authenticated encryption
Forward Secrecy (PFS) no-pfs	`Key Exchange: RSA, PFS: False`	+10	[MEDIUM]	Packet #8 (Offset 0)	No Perfect Forward Secrecy (PFS); static RSA key exchange enables retrospective traffic decryption

■ **ML ANOMALY ASSESSMENT (INDEPENDENT STATISTICAL LAYER)**
ML assessment runs in parallel as a secondary heuristic and does not inflate deterministic rule scores.
Risk Label: **MEDIUM** (35% conf) | Anomaly Detected: **NO** | Score: **0.162** | Architecture: **RandomForest Classifier + IsolationForest Baseline**

[HIGH] **deprecated-tls-10:** TLS 1.0 is negotiated â€" deprecated by NIST and IETF (RFC 8996) **Pkt #8**

Category: deprecated-protocol **CWE:** CWE-326 **Standard Reference:** IETF RFC 8996, NIST SP 800-52 Rev.2

```
Remediation Guidance & Configuration:
# Generic: Disable deprecated TLS versions
# Ensure only TLS 1.2 and TLS 1.3 are enabled.
# Consult your MTA/IMAP server documentation for the specific config key.
# References: IETF RFC 8996, NIST SP 800-52 Rev.2
```

Observed on Wire: TLS Version: TLS1.0
Evidence Provenance Chain: 0c96a199e679... → Session [SMTP STARTTLS 10.0.1.20:55001 → 198.51.100.5:25] → Pkt #8 (Offset 0) → Observed: TLS Version: TLS1.0 → Finding #f883e1e3 → Rule: deprecated-tls-10

[HIGH] **weak-cipher:** A weak cipher suite is negotiated (no PFS or weak key exchange) **Pkt #8**

Category: weak-cipher **CWE:** CWE-327 **Standard Reference:** NIST SP 800-52 Rev.2

```
Remediation Guidance & Configuration:
# Generic: Remove weak cipher suites
# Disable: RC4, NULL, EXPORT, 3DES, MD5-based suites.
# Enable: AES-GCM, ChaCha20-Poly1305 with ECDHE/DHE key exchange.
# Reference: NIST SP 800-52 Rev.2, Mozilla SSL Configuration Generator
```

Observed on Wire: Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA
Evidence Provenance Chain: 0c96a199e679... → Session [SMTP STARTTLS 10.0.1.20:55001 → 198.51.100.5:25] → Pkt #8 (Offset 0) → Observed: Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA → Finding #141dac3b → Rule: weak-cipher

[MEDIUM] **no-pfs:** Cipher suite does not provide Perfect Forward Secrecy (PFS) **Pkt #8**

Category: no-forward-secrecy **CWE:** CWE-311 **Standard Reference:** NIST SP 800-52 Rev.2 Â§3.3.1

```
Remediation Guidance & Configuration:
# Generic: Enable Perfect Forward Secrecy
# Configure your server to prefer ECDHE or DHE key exchange.
# Disable static RSA key exchange.
# Reference: NIST SP 800-52 Rev.2 §3.3.1
```

Observed on Wire: Key Exchange: RSA, PFS: False
Evidence Provenance Chain: 0c96a199e679... → Session [SMTP STARTTLS 10.0.1.20:55001 → 198.51.100.5:25] → Pkt #8 (Offset 0) → Observed: Key Exchange: RSA, PFS: False → Finding #3d9bc180 → Rule: no-pfs

Host: 45.33.32.156:25 — Grade D (Weak) (Score: 50)

■■ SECURITY POSTURE GRADE: D — WEAK (Risk Score: 50/100, Bracket: 31-50)
Host '45.33.32.156:25' received Posture Grade D (Weak) with a cumulative risk score of 50/100 (Bracket: 31-50). This grade was determined by 2 adverse findings (1 Critical, 1 Medium).

```
■ Host Posture Score Breakdown: 50 / 100 (Grade D) — 2 security findings mapped to score contributions.

Host Posture Score (45.33.32.156:25 - Grade D [Weak]): 50 / 100
Severity: GRADE D (WEAK)

WHY?
■■■ STARTTLS Negotiation (TLS Version...   +40
■■■ ml-anomaly (anomaly-score)            +10
■■■ Total                                 50
```

Session #2: SMTP	**Flow:** 10.0.2.30:56001 → 45.33.32.156:25	**TLS Version:** unknown	**PFS:** NO (No PFS)
Cipher: unknown	**Key Exch:** unknown	**SNI:** None	**ML Risk:** medium (35%)

■ WHY THIS SCORE? — Transparent Risk Reasoning **Risk Score: 50 / 100 (CRITICAL)**

```
Session Risk Score: 50 / 100
Severity: CRITICAL

WHY?
■■■ STARTTLS Negotiation (TLS Version...   +40
■■■ ml-anomaly (anomaly-score)            +10
■■■ Total                                 50
```

Finding / Feature	Observed on Wire	Impact	Severity	Evidence Ref	Reason & Rationale
STARTTLS Negotiation starttls-downgrade	**TLS Version: unknown**	**+40**	**[CRITICAL]**	Packet #17 (Offset 0)	STARTTLS offered in server banner was stripped or omitted during client negotiation
ml-anomaly ml-anomaly	**anomaly-score**	**+10**	**[MEDIUM]**	Packet #15 (Offset 0)	Session flagged as anomalous by IsolationForest (score=-0.027)

■ ML ANOMALY ASSESSMENT (INDEPENDENT STATISTICAL LAYER)
ML assessment runs in parallel as a secondary heuristic and does not inflate deterministic rule scores.
Risk Label: **MEDIUM** (35% conf) | Anomaly Detected: **YES** | Score: **-0.027** | Architecture: **RandomForest Classifier + IsolationForest Baseline**

[CRITICAL] **starttls-downgrade:** STARTTLS downgrade attack suspected â€" plaintext continued after STARTTLS command **Pkt #17**

Category: starttls-downgrade **CWE:** CWE-319 **Standard Reference:** RFC 3207, BASTA! research

```
Remediation Guidance & Configuration:
# STARTTLS stripping/downgrade was detected.
# Mitigations:
# 1. Postfix: Set smtp_tls_security_level = encrypt and
# smtpd_tls_security_level = encrypt to reject plaintext.
# 2. Deploy MTA-STS (RFC 8461) to publish a policy that requires TLS.
# 3. Publish SMTP TLS Reporting (TLSRPT) records (RFC 8460) to receive
# downgrade alerts.
# 4. Consider DANE (RFC 7671) for DNSSEC-authenticated TLS enforcement.
# References: RFC 8461 (MTA-STS), RFC 3207 (STARTTLS), BASTA! research
```

Observed on Wire: TLS Version: unknown
Evidence Provenance Chain: 0c96a199e679... → Session [SMTP 10.0.2.30:56001 → 45.33.32.156:25] → Pkt #17 (Offset 0) → Observed: TLS Version: unknown → Finding #624742be → Rule: starttls-downgrade

[MEDIUM]	**ml-anomaly:** Session flagged as anomalous by IsolationForest (score=-0.027)	Pkt #15

Category: ml-anomaly **CWE:** **Standard Reference:**

Remediation Guidance & Configuration:
Investigate session for unusual TLS behavior or novel misconfiguration.

Observed on Wire: anomaly-score
Evidence Provenance Chain: 0c96a199e679... → Session [SMTP 10.0.2.30:56001 → 45.33.32.156:25] → Pkt #15 (Offset 0) → Observed: anomaly-score → Finding #f8805f58 → Rule: ml-anomaly

Host: 203.0.113.50:25 — Grade D (Weak) (Score: 35)

■■ SECURITY POSTURE GRADE: D — WEAK (Risk Score: 35/100, Bracket: 31-50)
Host '203.0.113.50:25' received Posture Grade D (Weak) with a cumulative risk score of 35/100 (Bracket: 31-50). This grade was determined by 2 adverse findings (1 High, 1 Medium).

■ Host Posture Score Breakdown: 35 / 100 (Grade D) — 2 security findings mapped to score contributions.

```
Host Posture Score (203.0.113.50:25 - Grade D [Weak]): 35 / 100
Severity: GRADE D (WEAK)

WHY?
■■■ Cipher Suite Security (Cipher Sui...   +25
■■■ Forward Secrecy (PFS) (Key Exchan...   +10
■■■ Total                                  35
```

Session #3: SMTP STARTTLS	**Flow:** 10.0.3.40:57001 → 203.0.113.50:25	**TLS Version:** TLS1.2	**PFS:** NO (No PFS)
Cipher: TLS_RSA_WITH_AES_128_CBC_SHA	**Key Exch:** RSA	**SNI:** None	**ML Risk:** medium (35%)

■ WHY THIS SCORE? — Transparent Risk Reasoning **Risk Score: 35 / 100 (HIGH)**

```
Session Risk Score: 35 / 100
Severity: HIGH

WHY?
■■■ Cipher Suite Security (Cipher Sui...   +25
■■■ Forward Secrecy (PFS) (Key Exchan...   +10
■■■ Total                                  35
```

Finding / Feature	Observed on Wire	Impact	Severity	Evidence Ref	Reason & Rationale
Cipher Suite Security weak-cipher	Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA	+25	[HIGH]	Packet #21 (Offset 0)	Insecure CBC/RC4/3DES or non-AEAD cipher suite negotiated without modern authenticated encryption
Forward Secrecy (PFS) no-pfs	Key Exchange: RSA, PFS: False	+10	[MEDIUM]	Packet #21 (Offset 0)	No Perfect Forward Secrecy (PFS); static RSA key exchange enables retrospective traffic decryption

■ ML ANOMALY ASSESSMENT (INDEPENDENT STATISTICAL LAYER)
ML assessment runs in parallel as a secondary heuristic and does not inflate deterministic rule scores.
Risk Label: **MEDIUM** (35% conf) | Anomaly Detected: **NO** | Score: **0.190** | Architecture: **RandomForest Classifier + IsolationForest Baseline**

[HIGH]	**weak-cipher:** A weak cipher suite is negotiated (no PFS or weak key exchange)	Pkt #21

Category: weak-cipher **CWE:** CWE-327 **Standard Reference:** NIST SP 800-52 Rev.2

Remediation Guidance & Configuration:

```
# Generic: Remove weak cipher suites
# Disable: RC4, NULL, EXPORT, 3DES, MD5-based suites.
# Enable: AES-GCM, ChaCha20-Poly1305 with ECDHE/DHE key exchange.
# Reference: NIST SP 800-52 Rev.2, Mozilla SSL Configuration Generator
```

Observed on Wire: Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA
Evidence Provenance Chain: 0c96a199e679... → Session [SMTP STARTTLS 10.0.3.40:57001 → 203.0.113.50:25] → Pkt #21 (Offset 0) → Observed: Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA → Finding #0ad571db → Rule: weak-cipher

[MEDIUM]	**no-pfs:** Cipher suite does not provide Perfect Forward Secrecy (PFS)	Pkt #21

Category: no-forward-secrecy **CWE:** CWE-311 **Standard Reference:** NIST SP 800-52 Rev.2 Â§3.3.1

```
Remediation Guidance & Configuration:
# Generic: Enable Perfect Forward Secrecy
# Configure your server to prefer ECDHE or DHE key exchange.
# Disable static RSA key exchange.
# Reference: NIST SP 800-52 Rev.2 §3.3.1
```

Observed on Wire: Key Exchange: RSA, PFS: False
Evidence Provenance Chain: 0c96a199e679... → Session [SMTP STARTTLS 10.0.3.40:57001 → 203.0.113.50:25] → Pkt #21 (Offset 0) → Observed: Key Exchange: RSA, PFS: False → Finding #768d2044 → Rule: no-pfs

Host: 203.0.113.10:25 — Grade A+ (Excellent) (Score: 0)

■■ SECURITY POSTURE GRADE: A+ — EXCELLENT (Risk Score: 0/100, Bracket: 0)
Host '203.0.113.10:25' achieved Posture Grade A+ (Excellent) with a perfect score of 0/100. Zero security findings or cryptographic policy violations were detected across all analyzed sessions.

Session #4: SMTP STARTTLS	**Flow:** 10.0.0.5:54321 → 203.0.113.10:25	**TLS Version:** TLS1.2	**PFS:** YES (PFS)
Cipher: TLS_AES_128_GCM_SHA256	**Key Exch:** unknown	**SNI:** None	**ML Risk:** medium (35%)

■ WHY THIS SCORE? — Transparent Risk Reasoning **Risk Score: 0 / 100 (CLEAN)**

```
Session Risk Score: 0 / 100
Severity: CLEAN

WHY?
■■■ No security findings detected          +0
■■■ Total                                  0
```

■ ML ANOMALY ASSESSMENT (INDEPENDENT STATISTICAL LAYER)
ML assessment runs in parallel as a secondary heuristic and does not inflate deterministic rule scores.
Risk Label: **MEDIUM** (35% conf) | Anomaly Detected: **NO** | Score: **0.064** | Architecture: **RandomForest Classifier + IsolationForest Baseline**

✓ No security vulnerabilities or policy violations detected in this session.

4. PACKET-LEVEL EVIDENCE MAPPING

Verifiable provenance chain mapping each forensic finding to packet numbers, byte offsets, and observed wire values without altering source captures.

Finding ID / Rule	Session Flow	Pkt / Offset	Observed Wire Value	Evidence Chain
deprecated-tls-10 #f883e1e3	SMTP STARTTLS 10.0.1.20:55001 → 198.51.100.5:25	Pkt #8 (Off 0)	TLS Version: TLS1.0	0c96a199e679... → Session [SMTP STARTTLS 10.0.1.20:55001 → 198.51.100.5:25] → Pkt #8 (Offset 0) → Observed: TLS Version: TLS1.0 → Finding #f883e1e3 → Rule: deprecated-tls-10
weak-cipher #141dac3b	SMTP STARTTLS 10.0.1.20:55001 → 198.51.100.5:25	Pkt #8 (Off 0)	Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA	0c96a199e679... → Session [SMTP STARTTLS 10.0.1.20:55001 → 198.51.100.5:25] → Pkt #8 (Offset 0) → Observed: Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA → Finding #141dac3b → Rule: weak-cipher
no-pfs #3d9bc180	SMTP STARTTLS 10.0.1.20:55001 → 198.51.100.5:25	Pkt #8 (Off 0)	Key Exchange: RSA, PFS: False	0c96a199e679... → Session [SMTP STARTTLS 10.0.1.20:55001 → 198.51.100.5:25] → Pkt #8 (Offset 0) → Observed: Key Exchange: RSA, PFS: False → Finding #3d9bc180 → Rule: no-pfs
starttls-downgrade #624742be	SMTP 10.0.2.30:56001 → 45.33.32.156:25	Pkt #17 (Off 0)	TLS Version: unknown	0c96a199e679... → Session [SMTP 10.0.2.30:56001 → 45.33.32.156:25] → Pkt #17 (Offset 0) → Observed: TLS Version: unknown → Finding #624742be → Rule: starttls-downgrade

ml-anomaly #f8805f58	SMTP 10.0.2.30:56001 → 45.33.32.156:25	Pkt #15 (Off 0)	`anomaly-score`	`0c96a199e679... → Session [SMTP 10.0.2.30:56001 → 45.33.32.156:25] → Pkt #15 (Offset 0) → Observed: anomaly-score → Finding #f8805f58 → Rule: ml-anomaly`
weak-cipher #0ad571db	SMTP STARTTLS 10.0.3.40:57001 → 203.0.113.50:25	Pkt #21 (Off 0)	`Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA`	`0c96a199e679... → Session [SMTP STARTTLS 10.0.3.40:57001 → 203.0.113.50:25] → Pkt #21 (Offset 0) → Observed: Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA → Finding #0ad571db → Rule: weak-cipher`
no-pfs #768d2044	SMTP STARTTLS 10.0.3.40:57001 → 203.0.113.50:25	Pkt #21 (Off 0)	`Key Exchange: RSA, PFS: False`	`0c96a199e679... → Session [SMTP STARTTLS 10.0.3.40:57001 → 203.0.113.50:25] → Pkt #21 (Offset 0) → Observed: Key Exchange: RSA, PFS: False → Finding #768d2044 → Rule: no-pfs`